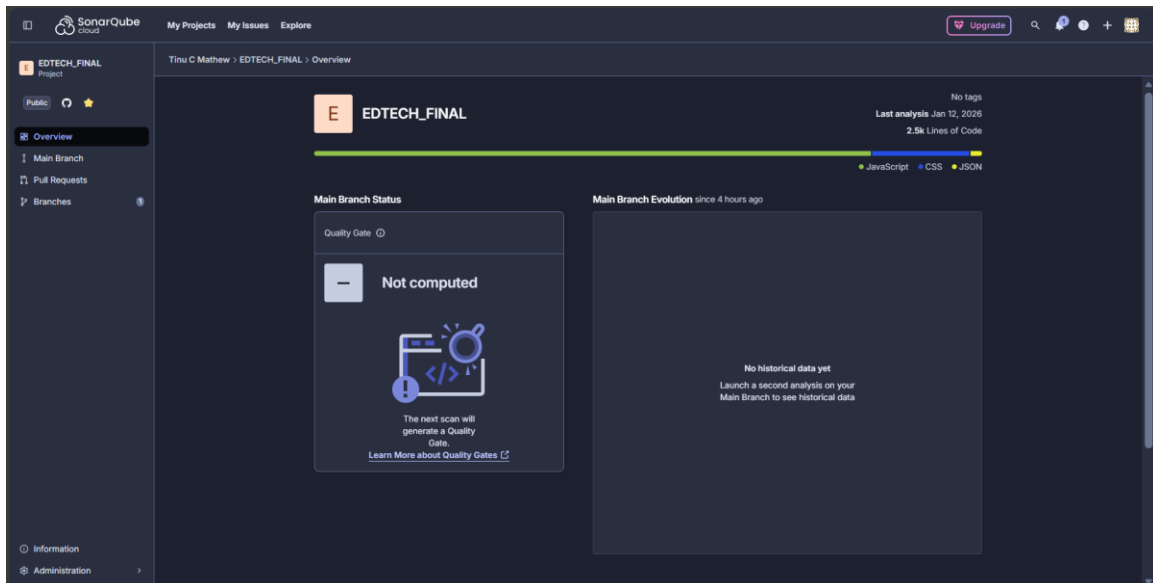


# Static Application Security Testing (SAST) Report

## 1. Introduction

Static Application Security Testing (SAST) is a security testing methodology used to analyze an application's source code without executing it. The goal of SAST is to identify security vulnerabilities, insecure coding practices, and potential risks early in the software development lifecycle.

This report documents the SAST analysis performed on the Studypilot application using SonarCloud.



## 2. Tool Used

Tool Name: SonarCloud

Type: Static Application Security Testing (SAST)

Platform: Cloud-based

Integration: GitHub

Analysis Mode: Static source code analysis (no runtime execution)

## 3. Project Details

Project Name: Studypilot

Repository Owner: Tinu C Mathew

Branch Analyzed: main

Lines of Code: ~8.6k

Scan Date: January 2026  
Technology Stack: MERN Stack

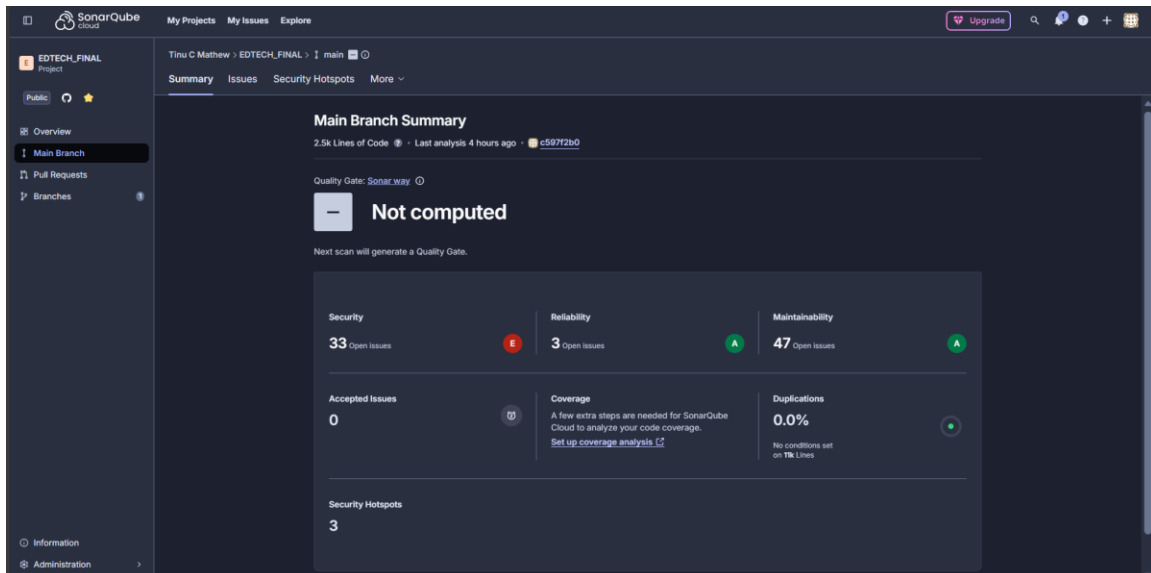
#### 4. Methodology

1. Source code hosted on GitHub
2. SonarCloud integrated using GitHub authentication
3. Repository imported and analyzed automatically
4. Static analysis performed without executing the application
5. Results reviewed from SonarCloud dashboard

#### 5. Scan Summary

Lines of Code Analyzed: 8.6k  
Quality Gate: Not Computed (Baseline Scan)

Security Issues: 57  
Reliability Issues: 29  
Maintainability Issues: 145  
Security Hotspots: 8



#### 6. Identified Vulnerabilities

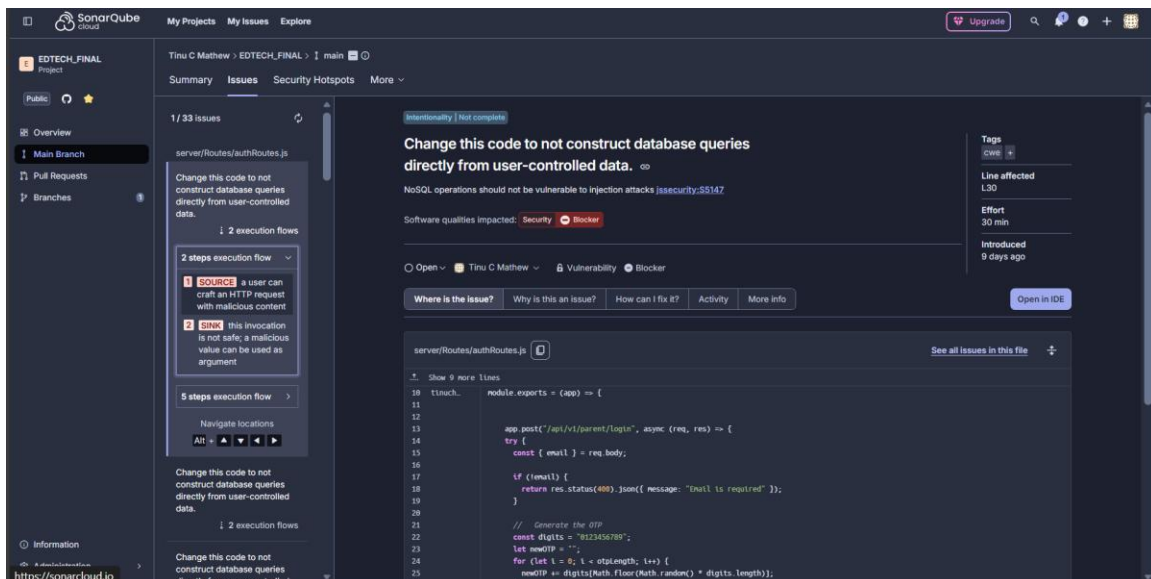
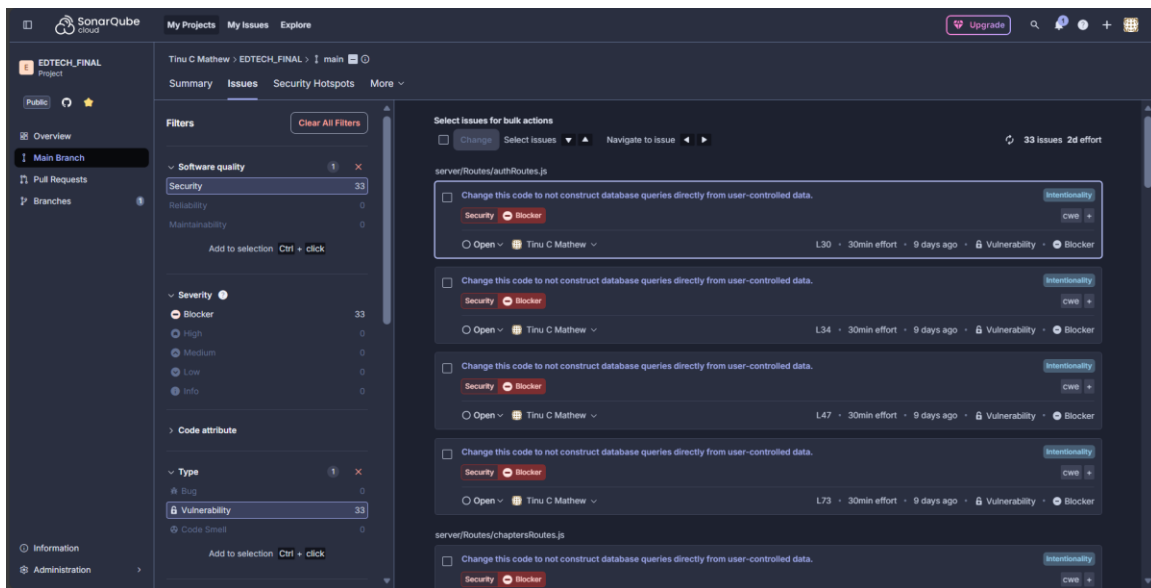
Example Vulnerability: NoSQL Injection  
Severity: Blocker  
File: server/Routes/authRoutes.js  
Line: 12

## Description:

Database queries are constructed directly from user-controlled input, making the application vulnerable to NoSQL injection attacks.

## Recommendation:

Validate user input and avoid passing untrusted data directly into database queries.



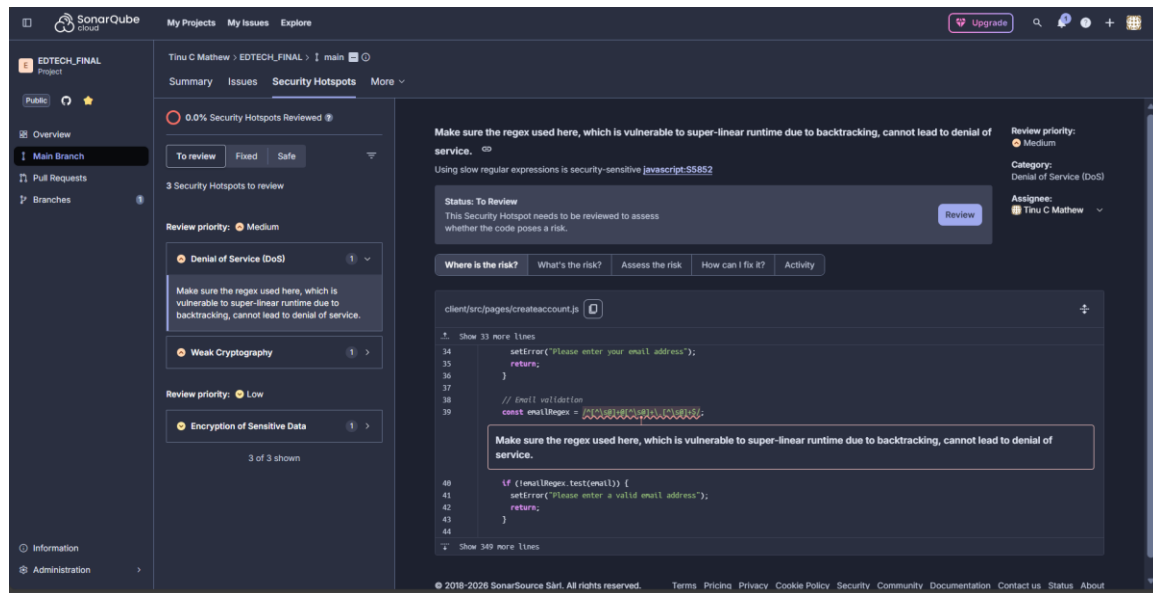
## 7. Security Hotspots

Security hotspots indicate sensitive code that requires manual review.

Example Hotspot:

Category: Denial of Service (DoS)

Issue: Unsafe regular expression leading to potential performance issues.



## 8. Conclusion

The SAST analysis using SonarCloud identified multiple security vulnerabilities and code quality issues. Addressing these findings will significantly improve the security and maintainability of the application.

## 9. Appendix

Tool: SonarCloud

Scan Type: Static Analysis

Report Prepared By: Tinu C Mathew